

SL1PCONNECT SAS

Processus de Gestion des Incidents de Sécurité

Security Operations Center (SOC)

Date	Juin 2026
Validé par	Denis THREADNEEDLE (DSI)
Périmètre	Infrastructure OVH + Siège Nice
Groupe	75 : Hugo, Louis, Envel, Cyran

1. Introduction et contexte

SL1PCONNECT SAS est spécialisée dans les sous-vêtements connectés (IoT santé). Elle traite des données physiologiques à caractère personnel sensible (DSCP - article 9 RGPD) hébergées sur PGSQL-HOST (10.0.1.30).

Incidents antérieurs documentés

Date	Criticité	Description	Lacune identifiée
Mars 2024	P1 CRITIQUE	Fuite 150 emails clients via SQLi sur BRIEF :8081	Pas d'audit global ; absence WAF
Juil. 2024	P1 CRITIQUE	Compromission compte admin BRIEF (mdp 'SI1p2024') - acces donnees sante 48h	Pas de notification CNIL art.33 dans les 72h
Jan. 2025	P2 ÉLÈVE	Tentative d'intrusion détectée par OVH (Russie, scan ports Docker)	Aucune action de fond ; pas de SIEM ; pas de playbook

Objectifs du présent document

- Fournir un cadre formel pour la détection, qualification et réponse aux incidents
- Intégrer les obligations RGPD (notification CNIL art.33 dans les 72h) et les exigences ISO 27001:2022
- Définir les roles, responsabilites et SLA pour chaque phase du traitement
- Fournir des playbooks opérationnels alignés sur la Cyber Kill Chain et MITRE ATT&CK
- Intégrer le processus au SIEM (Wazuh + TheHive) avec tickets automatisés

2. Classification des incidents - P1 à P4

2.1 Critères de qualification

La criticité d'un incident est déterminée selon trois axes (CIA). Le tableau ci-dessous définit les critères de déclenchement pour chaque niveau, au-delà des seuls exemples.

Niveau	Libellé	Critères de déclenchement	Exemples SL1PCONNECT	CNIL art.33
P1	CRITIQUE	Données de sante (DSCP) exposées OU confirmées - compromission avérée d'un compte à privilèges avec accès actif - service indisponible pour plus de 50% des utilisateurs - chiffrement en cours détecté - exfiltration confirmée	SQLi BRIEF + accès PGSQL-HOST, ransomware actif, compromission AD Bender/Roger, exfiltration DSCP	OBLIGATOIRE si DSCP exposées
P2	ELÈVE	Tentative d'intrusion détectée avec exploitation partielle - brute force abouti sans accès DSCP confirme - anomalie sur actif critique sans compromission confirmée - credential expose sans utilisation avérée	Scan massif ports Docker, brute force BRIEF abouti, API BOXER scrappée, Grafana credentials défaut utilisés	A évaluer avec DPO
P3	MOYEN	Comportement anormal détecté sans impact confirme - alerte SIEM sur actif non critique - violation de politique de sécurité sans accès - tentative échouée documentée	Brute force BRIEF échoué, MFA fatigue sans succès, trafic POST sortant anormal, CVE détectée (Trivy), logs absents	Non requis
P4	FAIBLE	Signalement utilisateur non urgent - anomalie de configuration sans exposition - vulnérabilité détectée sans exploitation active - écart de conformité PSSI isolé	Rotation des SSH manquante, patch en retard, mdp non conforme PSSI, log d'accès inhabituel hors heures bureaux	Non requis

SLA par niveau

Niveau	SLA Réponse	SLA Résolution	Escalade si dépassement	Action TheHive automatique
P1	1 heure	4 heures	CEO Slipman + DPO Payloadet	Alerte critique, réassignation auto, SMS DSI
P2	4 heures	8 heures	DSI Denis THREADNEEDLE	Alerte haute priorité, flag ticket TheHive
P3	1 jour	3 jours	Consultant SOC	Rappel automatique J+1
P4	3 jours	1 semaine	Rapport mensuel SOC	Rapport hebdomadaire

2.2 Critères CIA - Qualification

Axe	Questions à se poser	Impact sur la criticité
Confidentialité	Des DSCP (art.9 RGPD) ont-elles été exposées ? Combien de personnes ? Durée d'exposition ?	DSCP exposées => P1 minimum. Données personnelles simples => P2 minimum.
Intégrité	Des données ont-elles été modifiées sans autorisation ? Un système est-il compromis ?	Compromission actif critique (BOXER/BRIEF/PGSQL-HOST) => P1 ou P2 selon périmètre.
Disponibilité	Un service critique est-il indisponible ? Quel impact métier ? Depuis combien de temps ?	Plateforme IoT indisponible => P1. Services secondaires => P3.

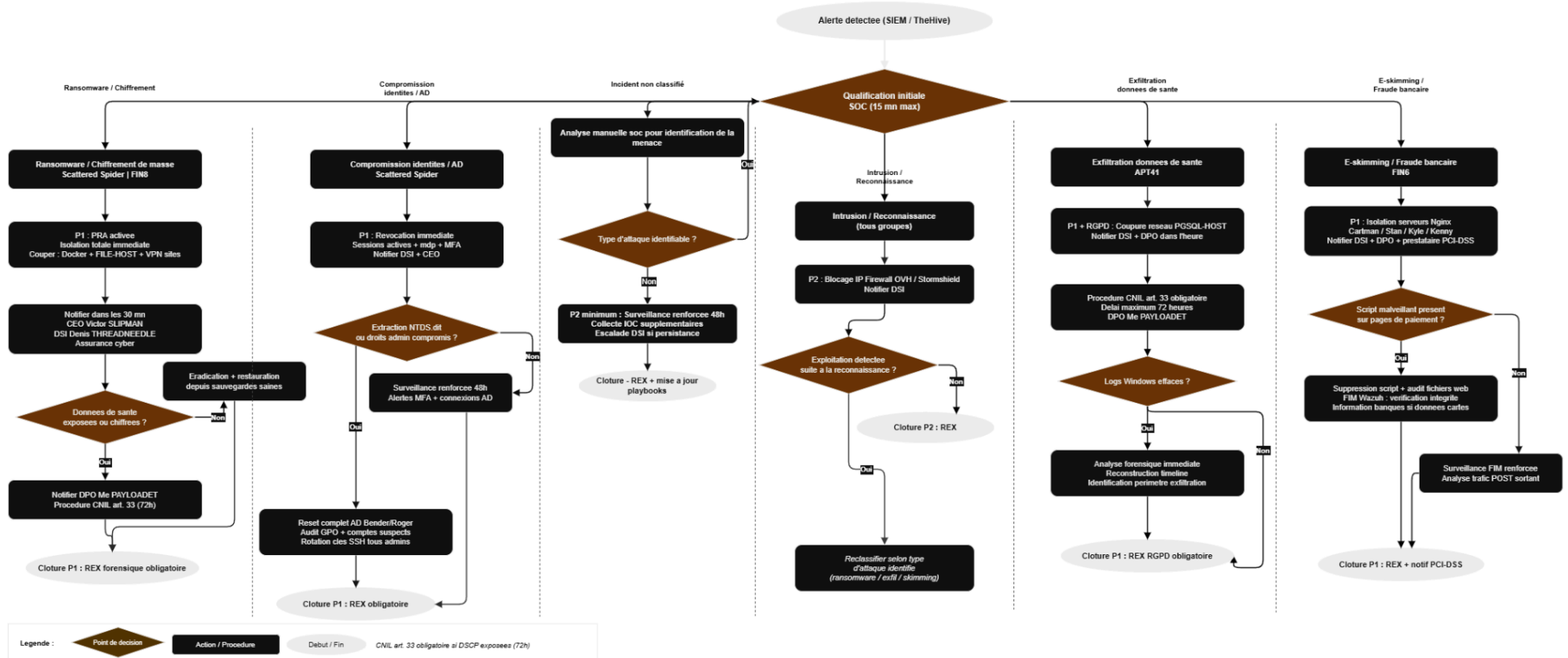
3. Workflow - 6 phases de traitement

Chaque phase comporte un critère de sortie avant passage à la suivante. La règle d'escalade automatique s'applique : tout incident P1 ou P2 déclenche une notification au DSI et l'ouverture d'un ticket TheHive. En cas de données de santé (DSCP) exposées, le DPO est notifié dans l'heure et la procédure CNIL art.33 est déclenchée.

#	Phase	Acteur principal	Actions clés	Critère de sortie
1	DETECTION / ALERTING	SOC / SIEM	Réception alerte SIEM (Wazuh) - vérification log source - ouverture ticket TheHive automatique - premier contact DSI si indicateurs critiques	Faux positif => clôture / Incident qualifié => Phase 2
2	QUALIFICATION / TRIAGE	SOC	Analyse IOC et contexte - classification P1/P2/P3/P4 (CIA + impact RGPD) - notification DSI Denis THREADNEEDLE - mise à jour ticket TheHive	Criticité définie, acteurs notifiés, endiguement lancé
3	ENDIGUEMENT	DSI + SOC	Isolation système compromis (docker stop / coupure réseau OVH) - blocage IP source /32 - préservation preuves (logs, snapshots) - notification DPO si DSCP impactées	Système isolé, preuves préservées, propagation stoppée
4	ERADICATION	DSI + Admin sys	Suppression vecteur d'attaque (patch, reset mdp, purge image Docker) - scan Trivy images - revocation credentials compromis (AD Bender/Roger) - vérification absence persistance	Système propre confirmé par scan et tests fonctionnels
5	RETOUR A LA NORMALE	DSI + SOC	Restauration service depuis sauvegarde validée - tests fonctionnels (API BOXER, admin BRIEF, PGSQL-HOST) - surveillance renforcée 48h post-incident - mise à jour règles SIEM si nouveau vecteur	Service validé par tests, monitoring actif
6	CLÔTURE / REX	SOC + DSI + DPO	Cloture ticket TheHive avec rapport final - rédaction REX obligatoire P1/P2 - mise à jour playbook si nouveau scénario - rapport mensuel SOC + revue ISO 27001	REX rédige et valide, ticket clos, documentation mise à jour

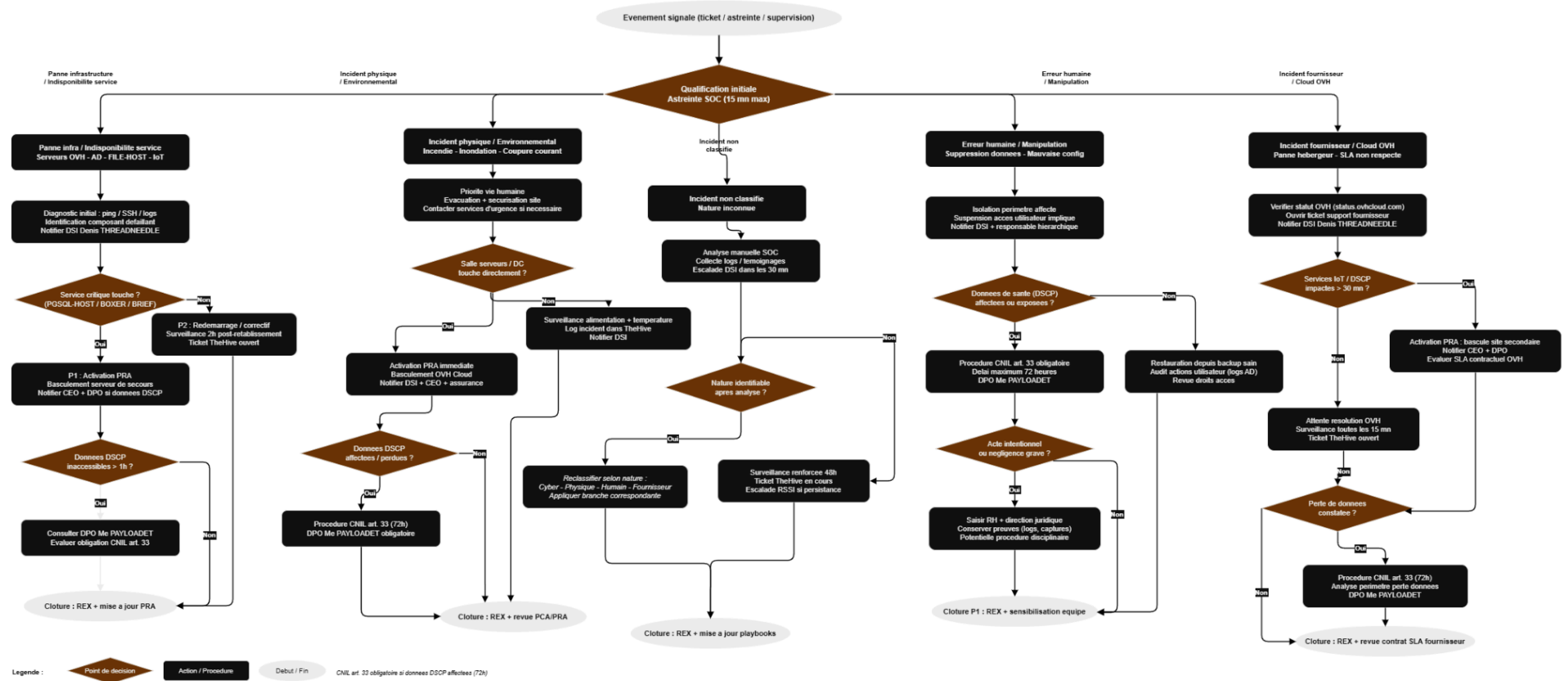
Workflow basé sur les analyses de menaces (plus technique)

SL1PCONNECT SAS : Arbre de decision SOC | Processus macro de reponse aux incidents



Workflow général type opérationnels et environnementaux

SL1PCONNECT SAS : Arbre de décision SOC | Incidents opérationnels et environnementaux



4. Matrice RACI - Roles et responsabilites

R = Responsable (execute) | A = Accountable (redevable, signe) | C = Consulte (avis requis) | I = Informe (notification)

Phase	SOC	DSI	DPO	CEO	Admin sys	Outil
Detection / Alerting	R	I	I	I	I	SIEM / TheHive
Qualification / Triage	R	C	I	I	I	TheHive
Endiguement	C	R	I	I	C	Firewall OVH / SSH
Notification CNIL (si DSCP)	C	I	R	A	I	Teleservice CNIL
Eradication technique	C	R	I	I	R	SSH / Docker / AD
Retour à la normale	R	C	I	I	C	TheHive / Tests
Clôture / REX	R	A	C	I	I	TheHive / Word

5. Playbooks de réponse aux incidents

Chaque playbook est structuré autour de la Cyber Kill Chain (7 phases) et des TTPs MITRE ATT&CK correspondants. Le SOC détecte l'ensemble de la chaîne d'attaque, du vecteur initial jusqu'aux actions finales.

PB	Nom	Criticité	Déclencheur SIEM	Actions T+0 a T+1h	ISO 27001	CNIL art.33
PB-01	Injection SQL BRIEF :8081	P1	SQLI-BRIEF-001 : pattern UNION/SELECT/DROP dans POST sur :8081	Blocage IP OVH + docker stop brief + snapshot DOCKER-HOST + DPO si DSCP	A.5.26 / A.8.25	Obligatoire si DSCP
PB-02	Compromission compte admin	P1	BRUTE-ADMIN-001 : plus de 10 échecs auth en 5mn sur BRIEF/WATCH/AD	Revocation session + reset mdp + activation MFA + notification DSI/CEO	A.5.15 / A.5.17	A évaluer
PB-03	Scan massif ports Docker	P2	PORTSCAN-OVH-001 : plus de 500 SYN/60s vers DMZ 10.0.1.0/24	Blocage IP OVH + reset mdp Grafana + restriction port 9090 LAN only	A.8.16 / A.8.20	Non requis
PB-04	Fuite données santé (DSCP)	P1 + CNIL	EXFIL-PGSQL-001 : transfert supérieur à 10MB depuis PGSQL-HOST vers IP externe en moins de 5mn	Coupure réseau PGSQL-HOST + DPO notifie + procédure CNIL art.33 activée	A.5.26 / A.5.34	Obligatoire (72h)
PB-05	Ransomware / PRA activée	P1 - PRA	RANSOM-FILE-001 : fichiers *.locked en masse en moins de 2mn ou CPU PGSQL supérieur à 95%	Isolation totale DOCKER-HOST + FILE-HOST en 5mn + PRA + CEO notifie + assurance cyber	A.5.30 / A.8.13	Si DSCP chiffrées

Le détail complet des 7 phases Kill Chain, les IOC par étape et les procédures horodatées de chaque playbook sont disponibles dans l'annexe A6.

6. Procédure RGPD - Notification CNIL art.33

Manquement constitue : L'incident de juillet 2024 (accès non autorisé aux données de santé pendant 48h) n'a pas été notifié à la CNIL dans les 72h. Ce risque de non-conformité doit être analysé par Me PAYLOADET (DPO). **Exposition :** amende pouvant atteindre 2% du CA mondial (art.83 RGPD, soit jusqu'à 840 000 EUR pour SL1PCONNECT au CA de 42 M EUR) ou sanction CNIL estimée entre 500 K et 1,5 M EUR au regard des précédents.

6.1 Arbre de décision - Déclenchement notification

Etape	Question	Décision
1	Des données personnelles ont-elles été compromises (accès, modification, perte, destruction) ?	NON => pas de notification CNIL OUI => etape 2
2	Ces données sont-elles des DSCP art.9 (santé, biométrie) ?	NON => etape 3 OUI => NOTIFICATION CNIL OBLIGATOIRE (72h)
3	Le risque pour les personnes est-il élevé (préjudice, discrimination, usurpation) ?	NON => documentation interne suffisante OUI => NOTIFICATION CNIL OBLIGATOIRE
4	Si notification requise : contacter DPO Me PAYLOADET immédiatement - délai max 72h à partir de la prise de connaissance	Via teleservice CNIL : notifications.cnil.fr

6.2 Contenu de la notification

- Nature de la violation (type de données, systèmes affectés)
- Nombre de personnes concernées (approximation si exacte impossible)
- Coordonnées DPO : Me I. PAYLOADET - Cabinet JurisFibre
- Conséquences probables de la violation
- Mesures prises ou envisagées pour remédier et limiter les conséquences
- Soumission via teleservice CNIL : notifications.cnil.fr

7. Integration SIEM - Wazuh / TheHive

7.1 Architecture de détection

- Sources de logs : Firewall OVH, Nginx BOXER-HOST, Apache BRIEF, Node.js SENSOR, Grafana WATCH, PostgreSQL PGSQL-HOST, AD Bender/Roger (Windows Event Logs)
- Collecte : agents Wazuh déployés sur DOCKER-HOST, PGSQL-HOST, FILE-HOST, serveurs Nice
- Correlation : regles Wazuh + Kibana Alerts via webhook vers TheHive
- Ticketing : TheHive - création automatique, assignation selon RACI, SLA calculé

7.2 Règles de corrélation SIEM

Règle ID	P	Condition de déclenchement	Source log	Playbook	ISO 27001
SQLI-BRIEF-001	P1	Pattern SQL (UNION/SELECT/DROP) dans POST sur BRIEF :8081	Apache BRIEF / Nginx	PB-01	A.5.26 / A.8.25
BRUTE-ADMIN-001	P1	Plus de 10 échecs auth en 5mn sur BRIEF/WATCH/AD (Event 4625)	Apache / Grafana / Win Event	PB-02	A.5.15 / A.5.17
PORTSCAN-OVH-001	P2	Plus de 500 SYN/60s depuis même IP vers DMZ 10.0.1.0/24	Firewall OVH / Wazuh Network	PB-03	A.8.16 / A.8.20
EXFIL-PGSQL-001	P1	Transfert supérieur à 10 MB depuis PGSQL-HOST vers IP externe en moins de 5mn	PostgreSQL / Firewall OVH	PB-04	A.5.26 / A.5.34
RANSOM-FILE-001	P1	Création massive fichiers *.locked en moins de 2mn ou CPU PGSQL supérieur à 95%	Wazuh FIM / Sysmon	PB-05	A.5.30 / A.8.13
API-NOAUTH-001	P2	Accès /api/* sur BOXER :8080 sans header Authorization	Nginx BOXER-HOST	PB-01/03	A.8.20 / A.8.25
DOCKER-ROOT-001	P2	Processus root dans conteneur avec exec vers PGSQL-HOST ou FILE-HOST	Wazuh Docker / Auditd	PB-01/05	A.8.25 / A.8.9
GRAFANA-DEFAULT-001	P2	Auth admin/admin réussie sur WATCH :9090	Grafana access.log	PB-03	A.5.15 / A.8.16

8. Processus de Retour d'Expérience (REX)

8.1 Obligations REX

- REX obligatoire pour tout incident P1 et P2
- REX P1 : rédigé sous 5 jours ouvrables après clôture
- REX P2 : rédigé sous 15 jours ouvrables
- REX P3/P4 : inclus dans le rapport mensuel SOC
- Revue trimestrielle des REX en Revue de Direction (point SSI ISO 27001 A.5.27)

8.2 Template REX

Section	Contenu attendu
Identifiant	INC-AAAAMMJJ-XXX Criticité P1/P2 Statut : CLOS
Chronologie	Timeline T+0 detection => endiguement => eradication => cloture
Description	Que s'est-il passé ? Quel système ? Quelles données ? Durée d'exposition ?
Cause racine	Analyse 5 Pourquoi : technique, humaine, organisationnelle
Impact	Donnees exposees, nombre de personnes, impact métier, impact RGPD/HDS
SLA respectés	SLA réponse et résolution tenus ? Si non : raisons et actions correctives
Leçons apprises	Correctifs court terme + recommandations long terme + mise à jour playbook
Validation	Consultant SOC DSI Denis THREADNEEDLE DPO (si RGPD)

9. KPIs et indicateurs de performance

KPI	Définition	Cible SL1PCONNECT	Mesure via
MTTD	Mean Time To Detect - temps moyen de détection	< 15 min (P1/P2)	Dashboard Kibana
MTTR	Mean Time To Respond - temps moyen de réponse	< 1h P1 < 4h P2	TheHive SLA tracker
Taux SLA respectés	% incidents traités dans le SLA défini	> 90%	Rapport mensuel TheHive
Taux faux positifs	% alertes SIEM non pertinentes	< 20%	Wazuh / Kibana
Couverture playbooks	% types incidents P1/P2 couverts par un playbook	100% P1/P2	Registre playbooks
REX produits dans les délais	% REX P1/P2 rédigés dans le délai défini	> 95%	Registre REX

10. Mapping ISO 27001:2022

Contrôle ISO 27001	Libellé	Section de ce document
A.5.24	Planification et préparation de la gestion des incidents	Sections 1, 2, 3
A.5.25	Evaluation et décision sur les événements de sécurité	Section 2 (classification P1-P4)
A.5.26	Réponse aux incidents de sécurité de l'information	Sections 3, 5 (playbooks)
A.5.27	Retour d'expérience des incidents	Section 8 (REX)
A.5.28	Collecte de preuves	Section 3, Phase 3 (préservation preuves)
A.5.34	Vie privée et protection des données personnelles	Section 6 (CNIL art.33)
À.6.8	Signalement des événements de sécurité	Section 3, Phase 1 (detection/alerting)
A.8.15 / A.8.16	Journalisation et activités de surveillance	Section 7 (SIEM / règles correlation)
A.5.30	Préparation TIC pour la continuité (PRA)	Section 5, PB-05 (Ransomware)

-- FIN DU DOCUMENT --